MODULE 23 · DOMAIN 5 - GOVERNANCE, SAFETY AND RISK MANAGEMENT

Human in the Loop

Where humans belong, review with real criteria, delegating by type of risk, the Usage Policy's high-risk rules, escalation and sampling.

DOMAIN 5 of 7 EXAM WEIGHT 14% MODULE 23 of 38

admin@sthithapragna.com

The surgical checklist happens before the incision. **Put humans where their judgement changes the outcome.**

Where humans belong

POSITION	ROLE	TYPICAL CASES
Before the action	Approve	Payments, filings that cannot be withdrawn, deletions
At a high-risk decision	Decide	Credit, medical, employment, housing
At escalation points	Take over	Weak evidence, vulnerability, a request for a human
After the fact, on samples	Audit	Routine, reversible outputs
In calibration	Label	Grader calibration, evaluation sets

ON THE EXAM

Irreversible or high-impact means before. Routine and reversible means sampling after.

Approval gates in agent systems

WHERE	HOW A PERSON GETS THE DECISION
Agent SDK	Ask rules send matching tool calls to your approval callback
Hooks	A PreToolUse hook can deny any call, before anything runs
MCP	The spec says a human should be able to deny tool calls
Your application	An approval queue in front of irreversible actions

ON THE EXAM

Gate the irreversible tool, not the whole conversation. People approve actions, not chatter.

Review that is more than a rubber stamp

- **Explicit criteria:** a short checklist of what to verify, not just looks fine.
- **Evidence at hand:** claims shown beside their cited sources.
- **Real authority:** the reviewer can change or reject, without penalty.
- **Enough time and context** for the stakes involved.
- **Warning signs:** near-total approval, few edits, seconds per item.

> ON THE EXAM
>
> A review nobody can fail is not a control. Measure edit rates and audit what was approved.

Delegate by type of risk, not by size

BY TRANSACTION SIZE

Auto-approve under a limit

- Small but wrong, at scale
- Manipulation aims just under the line
- Ignores who and why
- Easy to set, easy to game

BY TYPE OF RISK

Automate what is checkable

- Verifiable by system data: automate
- Policy-determined: automate, with limits in code
- Judgement or vulnerability: a human
- Novel or disputed: a human

THE TIEBREAKER

Size is one input to impact, not the rule. Ask what could go wrong, and whether it can be checked.

Usage Policy high-risk rules, effective 12 November 2026

REQUIREMENT	WHAT IT MEANS
High-risk areas	Legal, medical, finance, credit, insurance, housing, employment, and more
Qualified human review	Meaningful review, with authority to change, before advice or decision
Disclosure to the person affected	Told clearly that AI was used
Consumer chatbots and agents	Disclose they are AI, at least at the start of each session

ON THE EXAM

In high-risk areas, human review is a condition of use, not a design preference.

Escalation criteria

- **The person asks for a human:** always honoured, quickly.
- **Impact class** of the action about to be taken.
- **Weak evidence:** missing citations, disagreement across runs, grader flags.
- **Vulnerability, complaints or legal language** detected by classifiers.
- **Not the model's own I am not sure** alone: self-reported confidence is a weak signal.

> ON THE EXAM
>
> Escalation triggers are designed and tested, like any other control. Never only the model's mood.

Risk-stratified sampling

- **Everyone through the scanner,** some bags searched by hand.
- **Sample more** where impact is higher, categories are rare, or versions are new.
- **Keep a random slice** so unknown problems can still surface.
- **Reviewer decisions become labelled data:** every correction is a test case.
- **Adjust rates** as findings fall, or rise.

> THE PICTURE
>
> Airport security: everyone screened, some bags searched, more where the risk is.

Designing human review, in order

01
Classify
Each action by impact and reversibility.

02
Place checkpoints
Before, at, or after. Policy first.

03
Write criteria
What reviewers check, and their authority.

04
Set triggers
Escalation rules, tested.

05
Sample, label
Risk-stratified, into the eval set.

06
Measure, adjust
Edit rates, agreement, findings.

ON THE EXAM

Checkpoints follow the risk classification. Criteria follow the checkpoints. Never the other way round.

> Tallyhawk's head of support wants the agent to issue any service credit under USD 200 with no human review.
>
> Credits arise from outages, which the system logs, and from goodwill requests, where customers argue their case.

What should Corvane recommend?

A Approve the plan, since small amounts are low risk

B Automate outage credits the logs verify, within limits enforced in code; send goodwill credits to a person; sample the automated ones

C Require human review of every credit, whatever its type

D Keep the plan, but lower the limit to a much smaller amount

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Approve the plan, since small amounts are low risk

Persuasive customers and injected text aim just under the line.

B Automate outage credits the logs verify, within limits enforced in code; send goodwill credits to a person; sample the automated ones

Delegation by type: checkable work automated, judgement kept human.

C Require human review of every credit, whatever its type

Wastes review on credits the logs already prove.

D Keep the plan, but lower the limit to a much smaller amount

Still delegating by size, just a smaller line to game.

THE SIGNAL

Delegate by type of risk: verifiable and policy-bound is automated; argued and judgement-based goes to a person.

> Mereside wants Claude to approve or decline straightforward mortgage applications automatically, with no underwriter involved, to save time.
>
> The evaluation shows high agreement with past underwriter decisions.

What should Corvane advise?

A Allow it for straightforward cases only

B Allow it, provided applicants are told AI was used

C Allow it, since the evaluation shows high agreement

D A qualified underwriter must meaningfully review each recommendation with authority to change it, and applicants are told AI was used

◆ PAUSE AND DECIDE

What should Corvane advise?

A Allow it for straightforward cases only

Credit is a high-risk area whatever the case looks like.

B Allow it, provided applicants are told AI was used

Disclosure is required, but it does not replace review.

C Allow it, since the evaluation shows high agreement

Good results do not waive a condition of use.

D A qualified underwriter must meaningfully review each recommendation with authority to change it, and applicants are told AI was used

Both Usage Policy requirements for a high-risk area.

THE SIGNAL

Credit decisions are high-risk: qualified human review with authority, plus disclosure. Both, always.

> Quillon clinicians approve 99.6% of prior-authorisation letters without edits, spending about 20 seconds on each.
>
> An audit found several approved letters with claims the record did not support.

What should Corvane recommend?

A. Remove clinician review, since it almost never changes anything

B. Give reviewers a short checklist with claims beside their cited sources, track edit rates, and audit approved letters

C. Require two clinicians to approve each letter

D. Add a second AI model to approve letters before clinicians see them

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Remove clinician review, since it almost never changes anything

The audit proves review is needed; it is just not working.

B Give reviewers a short checklist with claims beside their cited sources, track edit rates, and audit approved letters

Makes review checkable, fast and measured.

C Require two clinicians to approve each letter

Two rubber stamps instead of one.

D Add a second AI model to approve letters before clinicians see them

May help as a layer; does not fix the human check.

THE SIGNAL

Near-total approval in seconds is a rubber stamp. Give reviewers criteria and evidence, then measure them.

> Tallyhawk's support agent escalates to a person only when it says it is not sure.
>
> Customers who ask for a human are kept with the agent, and conversations mentioning legal action are not escalated.

Which escalation design should Corvane recommend?

A Keep relying on the agent saying it is not sure

B Escalate every conversation after a fixed number of turns

C Escalate only billing conversations above a value

D Explicit triggers: a request for a human, legal or complaint language, classifier flags, weak evidence, and the action's impact

◆ PAUSE AND DECIDE

Which escalation design should Corvane recommend?

A. Keep relying on the agent saying it is not sure
Self-reported confidence is a weak signal, and misses all of these cases.

B. Escalate every conversation after a fixed number of turns
Arbitrary: floods staff, still misses urgent first messages.

C. Escalate only billing conversations above a value
Size again, and ignores legal and requests for humans.

D. Explicit triggers: a request for a human, legal or complaint language, classifier flags, weak evidence, and the action's impact
Designed triggers that cover the real risks.

THE SIGNAL

Escalation runs on designed, tested triggers. A request for a human is always honoured.

> Mereside's complaints triage handles about 3,000 complaints a month. The compliance team can review about 150.
>
> Some categories are rare, and some complaints carry vulnerability flags.

How should Corvane design the sample?

A. A simple random sample, up to capacity, each month

B. The first complaints received each month, up to capacity

C. Risk-stratified: all flagged or weak-evidence cases, rare categories over-sampled, plus a random slice, with corrections kept as labelled data

D. Only complaints from customers who complain again

◆ PAUSE AND DECIDE

How should Corvane design the sample?

A. A simple random sample, up to capacity, each month

Rare categories and flagged cases barely appear.

B. The first complaints received each month, up to capacity

Biased by timing, and blind to risk.

C. Risk-stratified: all flagged or weak-evidence cases, rare categories over-sampled, plus a random slice, with corrections kept as labelled data

Spends scarce review where the risk is, and still finds surprises.

D. Only complaints from customers who complain again

Finds harm only after it has happened twice.

THE SIGNAL

Scarce review goes where risk is highest, with a random slice kept for what nobody predicted.

> Calderbrook Housing Association wants a Claude agent to draft decisions on tenancy applications and transfers. Housing is a Usage Policy high-risk area.
>
> The team is about to write checklists for its reviewers.

Which two steps should come before writing the reviewer checklists? Choose two.

- A Classify each action the agent can take by impact and reversibility
- B Measure agreement between reviewers
- C Tune sampling rates using audit findings
- D Recruit additional reviewers for the team
- E Decide where checkpoints sit, starting from the Usage Policy's high-risk requirements

◆ PAUSE AND DECIDE

Which two steps should come before writing the reviewer checklists? Choose two.

A. Classify each action the agent can take by impact and reversibility
Step one: what could go wrong, and can it be undone?

B. Measure agreement between reviewers
Needs reviewers working to criteria first.

C. Tune sampling rates using audit findings
Needs a running system with findings.

D. Recruit additional reviewers for the team
Staffing follows the design, not the reverse.

E. Decide where checkpoints sit, starting from the Usage Policy's high-risk requirements
Step two: where review happens, and what is mandatory.

THE SIGNAL

Classify, then place checkpoints, then write criteria. Measurement and tuning come later.

In five lines

- **Before irreversible or high-impact actions;** sampling after routine, reversible ones.
- **Real review:** explicit criteria, evidence beside claims, authority, edit rates measured.
- **Delegate by type of risk,** not by size. Limits enforced in code.
- **High-risk areas:** qualified review with authority, and disclosure. Always.
- **Designed escalation triggers;** risk-stratified sampling; corrections become labels.

COMING UP

Next: compliance as architecture. GDPR, HIPAA, FedRAMP and the deployment platform.